Lab Writeups

Business Logic

PortSwigger Web Security Academy — Lab Solutions

Prepared by
Youssef Reda

Contents

Lab: Excessive Trust in Client-Side Controls 1

Lab: High-Level Logic Vulnerability 1

Lab: Inconsistent Security Controls 1

Lab: Flawed Enforcement of Business Rules 1

Lab: Low-Level Logic Flaw 2

Lab: Inconsistent Handling of Exceptional Input 2

Lab: Weak Isolation on Dual-Use Endpoint 2

Lab: Insufficient Workflow Validation 3

Lab: Authentication Bypass via Flawed State Machine 3

Lab: Infinite Money Logic Flaw 3

Lab: Authentication Bypass via Encryption Oracle 4

Bypassing Access Controls Using Email Address Parsing Discrepancies 4

Lab: Excessive Trust in Client-Side Controls

1. Log in with `wiener:peter` and attempt to buy the Lightweight l33t leather jacket; note that the order is rejected because the store credit is insufficient.
2. In Burp HTTP history, inspect the cart workflow and send the `POST /cart` request to Repeater. Identify the client-supplied `price` parameter.
3. Change `price` to an arbitrary integer and resend the request. Refresh the cart to confirm that the server accepts the modified price.
4. Set the price to an amount below the available store credit, then complete the order.

Lab: High-Level Logic Vulnerability

1. Log in with `wiener:peter` and add a cheap item to the cart.
2. In Burp HTTP history, inspect `POST /cart` and identify the `quantity` parameter.
3. Intercept another `POST /cart` request and change the quantity to an arbitrary integer. Forward the remaining requests and verify that the cart quantity changes.
4. Repeat with a negative quantity. Use a suitable negative value to make the cart contain a negative quantity and produce a negative total.
5. Add the Lightweight l33t leather jacket, then add a suitable negative quantity of another item to bring the total below the remaining store credit.
6. Place the order.

Lab: Inconsistent Security Controls

1. Use Burp Target Site map to discover content for the lab domain. Start the content discovery session and identify `/admin`.
2. Browse to `/admin`. The denial message indicates that users with the `dontwannacry.com` email domain are permitted.
3. Register an account using an arbitrary address in the format `anything@YOUR-EMAIL-ID.web-security-acade` obtain the email ID from the lab's Email client.
4. Open the confirmation email and activate the account.
5. Log in, open My account, and change the email address to an arbitrary `@dontwannacry.com` address.
6. Open the admin panel and delete `carlos`.

Lab: Flawed Enforcement of Business Rules

1. Log in with `wiener:peter`. Note the `NEWCUST5` coupon and subscribe to the newsletter to obtain `SIGNUP30`.
2. Add the Lightweight l33t leather jacket to the cart and proceed to checkout.
3. Apply both coupon codes. Test applying the same code twice and observe that consecutive reuse is blocked.
4. Alternate between `NEWCUST5` and `SIGNUP30` to bypass the reuse restriction and reduce the total below the remaining store credit.
5. Complete the order.

Lab: Low-Level Logic Flaw

1. Log in with `wiener:peter` and attempt to buy the jacket. In Burp, send the `POST /cart` request to Repeater.
2. Notice that each request accepts a two-digit quantity. Send the request to Intruder and set the quantity to `99`.
3. Select the Null payloads payload type and choose Continue indefinitely. Start the attack.
4. While it runs, refresh the cart and monitor the total. Repeated additions eventually overflow the signed 32-bit integer limit, causing the price to wrap from `2147483647` to `-2147483648`.
5. Clear the cart. Create a new Intruder attack with exactly 323 null payloads. In Resource pool, set Maximum concurrent requests to `1`, then start the attack.
6. When it finishes, send one `POST /cart` request from Repeater with quantity `47` for the jacket. The total should be `-$1221.96`.
7. Add a suitable quantity of another item so the total is above $0 and below the remaining $100 store credit.
8. Place the order.

Lab: Inconsistent Handling of Exceptional Input

1. Use Burp content discovery to find `/admin`. The access-denied response indicates that `dontwannacry.com` users can access it.
2. Open the lab Email client and note your unique email ID.
3. Register using an email address with a local part at least 200 characters long, for example very-long-string@YOUR-EMAIL-ID.web-security-academy.net. Activate the account through the confirmation email.
4. Log in and open My account. Observe that the stored email address has been truncated to 255 characters.
5. Register a second account using a sufficiently long local part and this domain: @dontwannacry.com.YOUR-EMAIL-ID.web-security-academy.net. Adjust the local-part length so the final `m` in `@dontwannacry.com` is character 255.
6. Activate the second account using the email client, then log in and verify that the truncated address is treated as a valid `@dontwannacry.com` address.
7. Open the admin panel and delete `carlos`.

Lab: Weak Isolation on Dual-Use Endpoint

1. Log in with `wiener:peter` and open My account.
2. Change your password and send the `POST /my-account/change-password` request to Burp Repeater.
3. Remove the `current-password` parameter and resend the request. Observe that the password change succeeds without the current password.
4. Change the `username` parameter to `administrator` and set a password of your choice. Send the request.
5. Log out, sign in as `administrator` using the new password, then open the admin panel and delete `carlos`.

Lab: Insufficient Workflow Validation

1. Log in with `wiener:peter` and buy any item affordable with your store credit.
2. In Burp history, locate the `POST /cart/checkout` request and note the redirect to the order confirmation page.
3. Send `GET /cart/order-confirmation?order-confirmation=true` to Repeater.
4. Add the Lightweight l33t leather jacket to the cart, then resend the order-confirmation request.
5. Observe that the order completes without deducting the jacket's cost from your store credit.

Lab: Authentication Bypass via Flawed State Machine

1. Log in and observe that the application asks you to select a role before opening the home page.
2. Use Burp content discovery to identify `/admin`.
3. Try browsing to `/admin` from the role-selection stage and confirm that access is not yet granted.
4. Log out, enable Burp interception, and log in again.
5. Forward `POST /login`, then drop the following `GET /role-selector` request.
6. Browse to the lab home page. The role defaults to administrator, granting access to the admin panel.
7. Delete `carlos`.

Lab: Infinite Money Logic Flaw

1. Log in with `wiener:peter` and subscribe to the newsletter to obtain the `SIGNUP30` coupon.
2. Buy a $10 gift card, apply `SIGNUP30` at checkout, complete the order, and copy the generated gift-card code.
3. Open My account and redeem the code. Confirm that the process adds $3 to your store credit.
4. In Burp history, identify the `POST /gift-card` request and its `gift-card` parameter.
5. Open Settings > Sessions and add a session-handling rule. Under Scope, select Include all URLs.
6. Under Rule actions, select Run a macro and create a macro containing, in order: `POST /cart`, `POST /cart/coupon`, `POST /cart/checkout`, GET/cart/order-confirmation?order-confirmed=true, and `POST /gift-card`.
7. Configure the order-confirmation response to extract the generated gift-card code as a custom parameter named `gift-card`. Configure `POST /gift-card` to use that value from response 4.
8. Test the macro and verify that the gift-card value matches and the redemption request returns a redirect response. Save the rule.
9. Send `GET /my-account` to Intruder, choose Sniper and Null payloads, and set the attack to generate 412 payloads.
10. Set the attack's Resource pool Maximum concurrent requests to `1`, then start the attack. After it finishes, use the accumulated store credit to buy the jacket.

Lab: Authentication Bypass via Encryption Oracle

1. Log in with Stay logged in enabled and post a comment. Inspect the encrypted `stay-logged-in` cookie in Burp.
2. Submit a comment with an invalid email address. Observe the encrypted `notification` cookie and the reflected error text `Invalid email address: your-invalid-email`.
3. Send `POST /post/comment` and the corresponding `GET /post?postId=x` request to Repeater. Rename the tabs `encrypt` and `decrypt`.
4. In the decrypt request, replace the `notification` cookie with the `stay-logged-in` cookie and send it. Note the decrypted format, `wiener:timestamp`, and copy the timestamp.
5. In the encrypt request, set the email parameter to `administrator:timestamp`. Copy the resulting notification cookie and test it with the decrypt request.
6. Decode the cookie with URL decoding followed by Base64 decoding. The decrypted notification reveals the fixed 23-byte prefix `Invalid email address: `.
7. Add nine characters before the intended value, for example `xxxxxxxxxadministrator:timestamp`, then encrypt it.
8. URL-decode and Base64-decode the new cookie. In Repeater's Hex view, remove the first 32 bytes (two 16-byte blocks), then re-encode the remaining data.
9. Test the modified ciphertext with the decrypt request and confirm that the plaintext is only `administrator:timestamp`.
10. Send `GET /` to Repeater, remove the session cookie, and replace `stay-logged-in` with the forged ciphertext. Send the request and verify administrator access.
11. Open `/admin` and request `/admin/delete?username=carlos`.

Bypassing Access Controls Using Email Address Parsing Discrepancies

1. Open Register and try `foo@exploit-server.net`. Confirm that registration is blocked because the permitted domain is `ginandjuice.shop`.
2. Test the following ISO-8859-1 address and observe the security block: =?iso-8859-1?q?=61=62=63?=foo@ginandjuice.shop.
3. Test the UTF-8 variation =?utf-8?q?=61=62=63?=foo@ginandjuice.shop; observe that it is also blocked.
4. Test =?utf-7?q?&AGEAYgBj-?=foo@ginandjuice.shop. This variation passes the initial security check.
5. Register using =?utf-7?q?attacker&AEA-[YOUR-EXPLOIT-SERVER-ID]&ACA-?=@ginandjuice.shop, replacing the placeholder with your exploit-server ID.
6. Open the Email client and follow the confirmation link. The validation component accepts the apparent `ginandjuice.shop` domain, while the mail-processing component interprets the recipient as the exploit-server address.
7. Log in with the new account, open the Admin panel, and delete `carlos`.